

CAMS Exam Preparation

Domain D: Tools and Technologies to Fight Financial Crime (20 percent of Exam)

Advanced AML Training Framework - Ultimate Edition

Domain D: 20 percent of CAMS Exam — 1000+ Lines — Complete Coverage

Domain D Weight and Structure

Domain D represents 20 percent of the entire CAMS exam. This is the second largest domain and often the most technically challenging.

Key Statistics:

- Approximately 24-28 questions on Domain D
- Passing score requires approximately 75 percent overall
- Most missed questions are on data quality and AI explainability
- Time allocation: approximately 30-40 minutes for Domain D questions

Content Breakdown by Subtopic:

Subtopic	Approximate Questions
Digital Onboarding and KYC	5-7 questions
Transaction Monitoring Systems	6-8 questions
AI and Machine Learning	4-6 questions
Data Quality and Governance	4-5 questions
Sanctions and Payment Screening	3-4 questions
Investigation Tools	2-3 questions

[FOCUS] Data quality and silent feed failures are the **MOST** frequently tested concepts.

The Three-Step Analysis Method

For every Domain D question, follow this systematic approach.

Step 1: Identify the Core Technology Being Tested

- Is this about onboarding (KYC/E-KYC), monitoring (rules/ML), or data quality?
- Each technology has specific strengths and weaknesses tested repeatedly.

Step 2: Apply the Risk-Based Approach Lens

- What is the customer's risk level? (Low, Medium, High, PEP)
- The correct answer will ALIGN controls with risk level.
- One-size-fits-all is ALWAYS the wrong answer.

Step 3: Spot the Regulatory Priority

- Effectiveness (catching bad activity) ALWAYS beats efficiency (saving money)
- False negatives (missed SARs) are ALWAYS worse than false positives
- If in doubt, choose the answer that prioritizes detection over cost

[FOCUS] Questions that pit effectiveness against efficiency ALWAYS favor effectiveness.

- 1 Silent data feed failure detection
- 2 Fuzzy logic for sanctions screening
- 3 False negatives vs. false positives
- 4 Liveness detection with facial recognition
- 5 Model drift and recalibration requirements
- 6 AI explainability (SHAP, LIME)
- 7 FATF Travel Rule for VASPs
- 8 ATL and BTL statistical testing
- 9 Perpetual KYC trigger events
- 10 Network analysis for money mules

[ALERT] These 10 concepts appear on virtually every CAMS exam. Master them first.

Core Principle

All AML tools are only as effective as the data they receive. Poor data quality equals failed controls.

[DEF] Data Quality The degree to which data is complete, accurate, timely, consistent, valid, and unique for its intended use in AML monitoring.

Why Compliance Owns Data Quality:

- Regulators hold the Compliance Officer accountable for monitoring failures
- "The IT system failed" is not an accepted defense
- Compliance must DEFINE requirements, not just accept what IT provides
- Monthly data quality reporting to the Board is required

[ALERT] Exam trap: Assuming data quality is solely an IT responsibility. Compliance defines, monitors, and escalates.

Dimension	Definition for AML	Exam Scenario Example
Completeness	All required fields are populated with non-null values.	Customer ID is NULL on 12 per cent of transactions - cannot investigate.
Accuracy	Data correctly reflects the real-world transaction.	Amount field error: \$1,000 instead of \$10,000 - missed SAR.
Timeliness	Data is available for monitoring when needed.	24-hour feed latency - criminals move funds before monitoring runs.
Consistency	Same data has same format across all systems.	John Smith in core vs. J. Smith in monitoring - screening miss.
Validity	Data conforms to defined business rules and formats.	Date 2025-13-01 invalid - transaction dropped from queue.
Uniqueness	No duplicate records for the same entity.	Two customer IDs for same person - split KYC, missed aggregation.

[FOCUS] Completeness (missing data) and timeliness (latency) are the most frequently tested dimensions.

[SCENARIO] 34 Percent of International Wires Missing for 14 Months A bank's transaction monitoring system relies on daily data feeds from 17 upstream systems. An audit reveals that for 14 months, the feed from the international wire system silently failed for 34 percent of all wires. Those transactions never entered the monitoring system, never generated alerts, and were never reviewed. Estimated \$340 million in wires were not monitored. The failure was a technical misconfiguration with no error messages. No reconciliation controls existed to detect the gap.

Technical Root Causes of Silent Failures:

- Field name change in source system (customer.id renamed to cust_id)
- API pagination limit exceeded (only first 1,000 of 10,000 transactions ingested)
- Network firewall rule blocking specific ports (no error logged)
- File encoding mismatch (UTF-8 vs. ASCII causing silent truncation)
- Database connection pool exhaustion (transactions queued then dropped)

Regulatory Analysis:

- 1 34 percent missing data equals massive monitoring gap - material deficiency
- 2 No alerts could be generated for missing transactions
- 3 Absence of reconciliation controls is a foundational failure
- 4 Remediation requires fixing root cause AND retrospective review
- 5 SARs must be filed for any suspicious activity identified

[TRAP] The misconfiguration was accidental, so no compliance violation occurred.

[CORRECT] Correct: Bank must have controls to verify complete data ingestion. The gap requires retrospective review and SAR filing.

Three Layers of Reconciliation Controls

Banks must prove that ALL transactions entered the monitoring system. These controls run daily.

Layer 1: Record Count Reconciliation

- Method: Compare number of transactions sent by source vs. received by target
- Detects: Complete feed failures or large-scale transaction loss
- Limitation: Cannot detect data corruption or substitution
- Target: 100 percent match, investigate any discrepancy

Layer 2: Total Dollar Volume Reconciliation

- Method: Compare sum total value of all transactions source vs. target
- Detects: Partial data loss or substitution of transactions
- Limitation: Can be fooled if missing and extra amounts cancel out
- Target: 99.9 percent match, investigate ≥ 0.1 percent variance

Layer 3: Hash Total Reconciliation (Strongest)

- Method: Run SHA-256 hash on key fields (Customer ID, Amount, Date, Transaction ID) for all transactions. Compare source hash to target hash.
- Detects: ANY change, deletion, insertion, or reordering of transactions
- A single bit flip changes the entire hash - mathematical proof of integrity
- Target: 100 percent hash match

[ALERT] Audit finding: The bank could not demonstrate completeness of transaction monitoring data. This is an automatic regulatory finding without hash totals.

What Must Happen When Reconciliation Fails

Detecting a discrepancy is not enough. There must be a documented escalation and resolution process.

Required Timeframes:

- 0-4 hours: Automated alert to IT and Compliance operations team
- 4-24 hours: Root cause analysis initiated, workaround implemented if possible
- 24-48 hours: resolved, escalate to Compliance Officer
- 5 days: Escalate to Chief Compliance Officer (CCO)
- 30 days: Escalate to Board of Directors if still unresolved

Documentation Requirements:

- Every reconciliation run must be logged (date, time, results)
- Every exception must have a ticket number
- Root cause must be documented for every exception
- Remediation plan and completion date must be recorded
- Audit trail must be immutable (no deletion or modification)

[FOCUS] Weekly reconciliation when daily is required is a common exam deficiency scenario.

[SCENARIO] 12 Percent of Transactions Have NULL Customer ID A bank's transaction monitoring system flags a series of large wire transfers. When the analyst tries to investigate, the system shows the transactions are associated with a Customer ID: NULL value. The data issue has been present for 8 months. IT explains that when customers open accounts through the mobile app, the unique identifier sometimes fails to populate in the monitoring system. Approximately 12 percent of transactions cannot be linked to any customer record.

Impacts of Unlinked Transactions:

- Cannot determine which customer conducted which transaction
- Cannot assess customer risk level or conduct CDD
- Cannot file accurate SARs without customer identification
- Cannot apply customer-specific thresholds or scenarios
- Cannot conduct network analysis (nodes have no identity)

Required Remediation:

- 1 Fix root cause in mobile app data population immediately
- 2 Implement validation to prevent NULL Customer ID from entering monitoring
- 3 Retrospectively review 8 months of orphaned transactions
- 4 Attempt to link orphaned transactions to customers using other fields (account number, name, address)
- 5 File SARs for any suspicious activity found, even if customer cannot be identified

[TRAP] IT issues are operational and not a compliance concern. [CORRECT] Correct: Missing customer identification is a material AML deficiency requiring immediate remediation and retrospective review.

Shared Responsibility Model

Data quality is a partnership. Each party has specific, non-delegable accountabilities.

Role	Primary Responsibilities	Accountability Measures
Compliance	Define data requirements for monitoring. Establish data quality KPIs. Monitor and report metrics. Escalate material gaps.	Monthly data quality dashboard to management. Quarterly to Board
IT	Implement controls to meet requirements. Build reconciliation systems. Fix root causes. Provide SLAs for data availability.	System uptime and feed reliability reports. MTTR for data issues.
Business / Operations	Ensure source system data quality at point of entry. Validate customer data during onboarding. Correct data errors.	Data entry error rates. Timeliness of corrections.
Internal Audit	Periodically test data quality controls. Report deficiencies. Track remediation.	Audit findings and remediation status.

[ALERT] Compliance cannot simply accept whatever data IT provides. Compliance must define requirements and monitor quality.

Metrics That Must Be Tracked and Escalated

These KPIs should be reviewed monthly by management and quarterly by the Board.

Completeness Metrics:

- Data completeness percentage by source system (target: 99.9 percent or higher)
- Percentage of records with NULL Customer ID (target: 0 percent)
- Percentage of records with NULL Amount (target: 0 percent)
- Percentage of records with NULL Date (target: 0 percent)

Timeliness Metrics:

- Average latency from transaction time to monitoring availability
- Maximum latency (worst-case delay)
- Percentage of transactions available within SLA (target: 99 percent within 1 hour)

Reconciliation Metrics:

- Daily reconciliation exception rate by feed
- Aging of open exceptions (0-24h, 24-48h, 48h+)
- Number of unresolved exceptions exceeding 48 hours
- Number of silent failures detected and resolved

Accuracy Metrics:

- Error rate in critical fields (amount, currency, counterparty)
- Duplicate record rate across systems
- Data validation failure rate

[FOCUS] Monthly reporting of data quality metrics to management is a regulatory expectation, not optional.

Core Concept

Digital onboarding tools have transformed KYC, but each technology has specific strengths and weaknesses tested on the exam.

Key Onboarding Technologies Covered:

- E-KYC (Electronic Know Your Customer): Digital verification using government databases
- Digital Identity: Verified digital credentials (government-issued or private)
- Facial Recognition: Comparing selfie to government ID photo
- Liveness Detection: Ensuring the person is physically present (not photo or video)
- Biometrics: Fingerprint, voice recognition, behavioral biometrics
- Geolocation: Verifying customer's physical location during onboarding
- Document Verification: Scanning and validating passports, driver's licenses

[FOCUS] Exam tests which technology is appropriate for which risk scenario.

FATF Guidance on Digital ID (2019/2020)

Digital identity systems can be used for Customer Due Diligence if they provide equivalent assurance to face-to-face verification.

Assurance Level 1 - Low Assurance:

- Self-asserted data only, no verification against trusted source
- Example: User types name and email, no document upload
- NOT acceptable for any regulated financial service
- Exam trap: This is never the correct answer for AML compliance

Assurance Level 2 - Medium Assurance:

- Verified against trusted source (credit bureau, government ID database)
- Example: Name and address verified against credit report
- Acceptable for low-risk customers (basic retail account, low balance)
- May require additional controls for higher-risk activities

Assurance Level 3 - High Assurance:

- In-person or biometric verification with liveness detection
- Multi-factor authentication required
- Required for high-risk customers, PEPs, corporate accounts
- Example: Video call with agent, biometric scan with liveness

[REG] FATF Guidance on Digital ID, paras 78-95. [ALERT] Low assurance digital ID is NOT sufficient for regulated financial services.

Government Digital ID	Private / Digital Identity
Issued by national authorities (India Aadhaar, Estonia e-Residency, Singapore SingPass)	Issued by banks or tech companies (BankID Sweden, Verified.Me Canada, Apple/Google ID)
Typically high assurance enrollment	Varies from medium to high depending on verification
Can be mandatory for certain transactions	Voluntary, customer chooses to participate
Privacy concerns (government tracking of transactions)	Privacy-focused design often better
Acceptance often required by regulation	Acceptance varies by jurisdiction and institution
Single point of failure risk (if compromised)	Redundancy across multiple providers possible
[ALERT] Critical Exam Point: Government digital ID is NOT automatically compliant. It must still meet FATF assurance standards for the specific customer risk level.	

How Biometrics Bind Identity

Biometrics link an identity to physical or behavioral characteristics, making identity fraud more difficult.

Common Biometric Types and Their Vulnerabilities:

- Fingerprint: High accuracy, low cost. Attack: Can be lifted from surfaces, replicated with silicone. Defeated by multi-modal or liveness.
- Facial Recognition: Convenient (selfie), camera on every phone. Attack: Deepfakes, printed photos, video replay. Defeated by liveness detection.
- Voice Recognition: Works over phone channels. Attack: Recorded voice replay, AI voice synthesis. Defeated by challenge-response with random phrases.
- Iris Scanning: Very high accuracy, extremely low false accept rate. Attack: Requires high-resolution photo, very difficult. Limitation: Expensive hardware.
- Behavioral Biometrics: Keystroke dynamics, mouse movements, swipe patterns. Attack: Difficult to spoof. Advantage: Passive, continuous.

[FOCUS] Facial recognition alone is insufficient. Liveness detection is the required compensating control.

Liveness Detection Defined

Liveness detection ensures the biometric sample comes from a live, physically present person at the time of capture, not a spoof artifact.

Active Liveness (User Must Perform an Action):

- Instructions: Blink, smile, turn head left, say a random phrase
- Pro: High security, difficult to spoof with pre-recorded video
- Con: User friction, accessibility issues for disabled users
- Con: Requires user cooperation, may fail if user cannot perform action
- Best for: High-risk onboarding (PEPs, corporate accounts, large transactions)

Passive Liveness (No User Action Required):

- Analyzes: Micro-movements, skin texture, light reflection, depth mapping
- Analyzes video frames for natural motion (not present in photos or video replay)
- Pro: Seamless user experience, no friction
- Con: Slightly lower security against advanced deepfakes
- Best for: Low to medium risk, high-volume onboarding

Advanced Attacks and Defeats:

- Deepfake injection: Bypass camera, feed synthetic video directly to application. Defense: Hardware-backed camera, attestation.
- Replay attack: Play previously recorded liveness video. Defense: Random challenge phrases (cannot be pre-recorded).
- Morphing attack: Combine two faces to fool both recognition and liveness. Defense: Multi-modal (face + voice).

[ALERT] Banks must update liveness algorithms regularly as deepfake technology evolves rapidly.

What Document Verification Actually Checks

Identity document verification extracts and validates data from passports, driver's licenses, and national IDs.

MRZ (Machine Readable Zone) Validation:

- Validates format compliance (TD1, TD2, TD3, MRV formats)
- Checksum validation - each MRZ line has a check digit that must match calculation
- Extracts document number, date of birth, expiration date, nationality
- Common attack: Replace photo but keep MRZ intact - detected by biometric comparison

Security Feature Verification:

- Hologram detection: Laser engraving, optically variable ink
- UV feature detection: Watermarks, fluorescent fibers visible only under UV
- Microprinting verification: Requires high-resolution scanning
- RFID chip reading (e-passports): Highest assurance, optional, requires NFC

Common Forgery Techniques:

- Photographic substitution: Replace photo while keeping MRZ
- Data page replacement: Entire page swapped from another document
- Forged holograms: Cheap counterfeits detectable by angle testing
- Synthetic identity: Real document number with fake name - hardest to detect

[FOCUS] Document verification alone is not sufficient. Must be combined with biometrics and database checks.

Data Source Type	Example Providers	Primary AML Use
Credit Reference Agencies	Experian, Equifax, TransUnion	Address history verification, identity verification via knowledge-based authentication
Government ID Verification	GB Group, Acuant, Onfido, Jumio	Passport/driver's license validation against issuing authority database
Sanctions Lists	OFAC SDN, UNSC, EU Consolidated, UK HMT, DFAT	Screening against prohibited persons and entities
PEP Databases	Dow Jones WorldCheck, Refinitiv World-Check, LexisNexis, ComplyAdvantage	Identification of politically exposed persons and their relatives/associates
Adverse Media	Dow Jones Risk and Compliance, Refinitiv, ComplyAdvantage, Dataminr	Negative news monitoring, regulatory actions, court records
Beneficial Ownership	OpenCorporates, Sayari, Dun and Bradstreet, local registries	Corporate UBO identification, ownership structure mapping
Criminal Records	Sterling Check, HireRight (where legally permitted)	Past convictions relevant to financial crime
Internal Watch Lists	Bank proprietary lists	Previous SAR subjects, internal fraud alerts, 314(a) requests

Why Exact Matching is Never Sufficient

Sanctions list screening requires algorithmic matching to catch name variations, misspellings, and transliterations.

Phonetic Algorithms (Match by Sound):

- Soundex: First letter + 3 digits based on consonant sounds. Example: Smith and Smyth both become S530.
- Metaphone / Double Metaphone: More sophisticated, handles silent letters, multiple pronunciations. Example: Gadaffi and Qaddafi both become KTFF.
- NYSIIS (New York State Identification and Intelligence System): Optimized for surnames, better than Soundex for names with silent letters.

Edit Distance Algorithms (Match by Character Difference):

- Levenshtein distance: Minimum single-character edits (insert, delete, substitute) to change one string to another. Example: John to Jon has distance 1.
- Damerau-Levenshtein: Also counts transpositions (adjacent character swaps). Example: ab to ba has distance 1.
- Jaro-Winkler: Gives higher weight to matching prefixes. Good for short names. Example: Catherine and Kathryn have high similarity.

Token-Based Matching:

- Split name into tokens (first, middle, last, suffix)
- Compare tokens individually with fuzzy logic
- Requires name parsing logic for Jr., III, bin, bint, etc.

[FOCUS] You do not need to memorize algorithm details, but you MUST know that fuzzy logic or phonetic matching is required.

Batch Screening (Periodic)	Real-Time Screening (Transactional)
Screens entire customer database against updated lists	Screens each payment or transaction before processing
Frequency: Daily, weekly, or immediately after sanctions list update	Frequency: Per transaction (milliseconds latency required)
Detects: Customers who became sanctioned after onboarding	Detects: Prohibited transactions before funds move
Output: List of potential matches for manual review	Output: Hold, block, or allow with alert
Performance: Not time-critical (hours allowed for processing)	Performance: Sub-second (often less than 100ms)
False positives: Can be manually reviewed over days	False positives: Can cause payment delays - requires careful tuning
Required for: All customers, including dormant accounts	Required for: All wire transfers, crypto transactions, instant payments

[ALERT] Failure to screen dormant accounts during batch processing is a common exam deficiency scenario.

Typical Segments and Controls by Risk Level

Different customer types receive different levels of onboarding scrutiny based on inherent risk assessment.

Customer Type	Minimum Onboarding Controls	Enhanced Controls (if risk indicators)
Retail - Low Risk (payroll, low balance)	Basic CIP (name, DOB, address, ID number), identity verification	Not applicable
Retail - Medium Risk (small business owners)	Basic CIP plus beneficial ownership (if entity) plus sanctions screening	Source of funds if unusual activity appears
Retail - High Risk (MSB, NPO, crypto user)	Enhanced CDD plus source of funds plus PEP screening plus adverse media	Senior management approval
Corporate - Simple Structure	CIP for entity plus UBOs (25 percent plus ownership) plus sanctions	Business registry verification
Corporate - Complex Structure (trusts, layered)	Full EDD plus source of wealth plus multi-tier UBO identification plus independent verification	On-site visit
PEP (Foreign Senior Official)	Maximum EDD plus senior management approval plus source of wealth plus ongoing monitoring	Enhanced scrutiny for 12-18 months after leaving office
Correspondent Bank	Wolfsberg CBDDQ plus on-site inspection plus enhanced monitoring	No shell bank clause verification

Balancing Friction and Risk

Too much friction drives customers away or to competitors. Too little creates AML risk exposure.

Low-Friction (Good CX) Techniques:

- Digital onboarding with real-time verification (seconds, not days)
- Risk-based friction: Simplified Due Diligence for low-risk, EDD only for high-risk
- Transparent communication: Explain why information is needed and legal basis
- Biometric authentication replaces passwords for login
- Mobile-first document upload (scan passport with phone camera)
- Pre-filled forms using trusted data sources (credit bureau)

High-Friction (Bad CX) - Regulatory Red Flags (Over-Controlling):

- Requiring in-person branch visit for every account type (even low-risk)
- Asking all customers for source-of-wealth documentation (excessive)
- Repeatedly requesting same documents already provided
- No digital channel for KYC updates (must call or visit branch)
- Excessive hold times for customer verification

Regulatory View:

- FDIC, OCC, FinCEN have all warned that excessive friction without risk justification is poor management
- Over-controlling can be cited as a compliance program deficiency
- Risk-based approach applies to customer experience as well

[FOCUS] Exam tests ability to apply risk-based friction: low-risk equals low friction, high-risk equals high friction.

Typical Data Flow

Core Systems -> Data Aggregation -> Scenario Execution -> Alert Generation -> Case Management -> Investigation -> SAR Filing

Key Components with Technical Details:

- Data Ingestion Layer: Pulls from core banking, payments, CRM, trade finance. Must handle batch (nightly) and real-time (Kafka, RabbitMQ) feeds.
- Data Transformation Layer: Normalizes formats, maps fields, enriches with customer risk rating and segmentation.
- Scenario Engine: Executes pre-defined rules (SQL, Drools) or ML models (Python/TensorFlow). Must scale to millions of transactions daily.
- Alert Generation: Creates case in case management system. Includes priority score (high, medium, low) and assigned investigator.
- Case Management: Workflow for investigation, evidence collection, narrative writing, supervisory approval.
- Reporting Engine: Files SAR/STR to Financial Intelligence Unit, generates management dashboards.

[ALERT] Data latency (delay between transaction and monitoring) is a common regulatory deficiency.

Rules-Based Monitoring	Machine Learning Monitoring
Pre-defined, static rules written by analysts	Learns patterns from historical data (supervised, unsupervised, semi-supervised)
Easy to explain and audit (deterministic)	Black box problem - harder to explain (requires XAI like SHAP/LIME)
Low false positives if well-tuned (5-10 percent typical)	Can have high false positives (20-40 percent without careful tuning)
Misses new or evolving typologies (rules become stale)	Adapts to new patterns if retrained (online learning possible)
No model drift (rules don't change on their own)	Subject to model drift (performance degrades over time)
Simple implementation (SQL, rules engines)	Complex implementation (requires data science team)
Low computational requirements	High computational requirements (GPUs for deep learning)
Requires manual rule updates (change management)	Can retrain automatically (but validation still required)
Handles structured data only	Handles structured and unstructured (NLP for transaction notes)
Low data volume requirements	Requires large, labeled datasets for supervised learning

Confusion Matrix for AML Monitoring

	Predicted: Alert	Predicted: No Alert
Actual: Suspicious	True Positive (TP)	False Negative (FN) - MISSED
Actual: Legitimate	False Positive (FP) - WASTE	True Negative (TN)

Why False Negatives are Worse (Regulator Priority):

- Criminal activity proceeds undetected
- Money laundering continues
- Bank may face enforcement action (civil money penalties)
- Reputational damage if publicly exposed
- Potential criminal liability for willful blindness

Why False Positives are Problematic (Bank Priority):

- Analyst fatigue (reviewing too many false alerts leads to missed true positives)
- Operational cost (each false positive costs 25—75 to review)
- Slows down legitimate transactions (if real-time holds are applied)
- May cause customer attrition (if falsely accused of suspicious activity)

[REG] FinCEN expects institutions to prioritize detection effectiveness over operational efficiency. [ALERT] Ever increasing thresholds to reduce false positives equals unacceptable false negative risk.

[SCENARIO] Bank of America - 2019 Consent Order (paraphrased) A bank's compliance director, under pressure to reduce alert volume (8,000 per month, 96 percent false positives), raises all monitoring thresholds by 250 percent across all scenarios. The analytics team warns of increased false negatives, but the director states: We cannot afford to review 8,000 alerts per month. Any missed activity is acceptable as long as we still file some SARs. Regulators later find that criminal structuring activity below the new thresholds went undetected for 18 months.

What the Exam Tests: Over-filtering creates unacceptable false negative risk.

How to Analyze (Exam Logic):

- 1 250 percent threshold increase is extreme and arbitrary (no data analysis performed)
- 2 Many suspicious transactions will fall below new thresholds
- 3 Director prioritizing cost over effectiveness (violation of risk-based approach)
- 4 Statement any missed activity is acceptable is regulatory non-compliance
- 5 Regulators will view this as a material deficiency
- 6 Remediation requires back-testing missed period and filing SARs for identified suspicious activity

[TRAP] The director is correctly managing operational efficiency under the risk-based approach. [CORRECT] Correct: Raising thresholds must be based on data analysis and validation. Effectiveness cannot be sacrificed for efficiency.

ATL Testing Validates Scenario Effectiveness

Tests that transactions which SHOULD generate alerts actually do.

Methodology:

- 1 Identify historical confirmed suspicious cases (SARs filed, EDD findings)
- 2 Run those cases through current monitoring scenarios
- 3 Calculate capture rate equals (cases that generated alert) divided by (total cases)
- 4 Expected capture rate: 90-100 percent for well-tuned scenarios

Low Capture Rate Analysis (Below 90 percent):

- Investigate root cause immediately
- Scenario logic too narrow (missing variations of typology)
- Thresholds too high (over-filtering)
- Data quality issues (missing transactions, corrupted fields)
- Typology has evolved (scenario needs update)

Regulatory Expectation:

- ATL and BTL testing at least annually
- Material changes trigger interim testing
- Results must be documented and presented to management
- Remediation required for out-of-tolerance results

[ALERT] A 77 percent false negative rate on historical SARs is a material deficiency (actual regulatory finding).

BTL Testing Validates Scenario Specificity

Tests that transactions which SHOULD NOT generate alerts do not.

Methodology:

- 1 Identify known legitimate, low-risk transactions (e.g., payroll deposits)
- 2 Run those transactions through current monitoring scenarios
- 3 Calculate false positive rate equals (transactions that generated alert) divided by (total test transactions)
- 4 Expected false positive rate: 0-10 percent for well-tuned scenarios

High False Positive Rate Analysis (Above 10 percent):

- Investigate root cause
- Scenario logic too broad (over-inclusive)
- Thresholds too low (under-filtering)
- Customer segmentation issues (same rules for different risk tiers)
- Data quality issues (corrupted fields causing false matches)

Regulatory View:

- High false positive rates waste resources and cause analyst fatigue
- Less severe than false negatives, but still a deficiency
- Excessive false positives may indicate poor scenario design

[FOCUS] BTL testing is often overlooked by banks - exam tests whether you know it is required.

Typology	Example Scenario Logic	Key Indicators
Structuring (Smurfing)	Aggregate cash deposits less than \$10,000 within rolling 30-day window	Multiple deposits just below low CTR threshold, multiple branches, multiple tellers
Layering	Transfers through 3 or more accounts in less than 24 hours	Rapid movement across accounts, no economic purpose, round numbers
Trade-Based ML	Invoice value vs. market price variance greater than 20 percent	Round-dollar trade payments, commodity mismatch, high risk jurisdiction counterparty
Shell Company Activity	Transfer to or from offshore financial center plus no operating expenses	No payroll, no rent, no utilities but high transaction volume
PEP Activity	Large unexplained transfer (greater than \$100k) plus PEP flag	Source of funds not documented, complex ownership structure
NPO or Terrorist Financing	Rapid cash withdrawal from NPO account plus conflict zone activity	Donations from unrelated parties, immediate wire to high risk region
Cybercrime or Ransomware	Payment to known ransomware wallet plus unusual timing	Ransomware address on watchlist, payment matches victim report

Beyond Periodic Refresh

Perpetual KYC continuously monitors customer data and risk indicators, triggering reviews when changes occur rather than waiting for scheduled refresh.

Data Sources for Perpetual KYC:

- Real-time transaction monitoring (behavioral changes, velocity, counterparty risk)
- Adverse media feeds (continuous news screening via API)
- Sanctions and PEP list change detection (delta files processed daily)
- Corporate registry monitoring (UBO changes, dissolution, new filings)
- Negative media monitoring (social media, blogs, forums - with verification)

Trigger Events Requiring Unscheduled Refresh:

- Change in ownership structure (new UBO greater than 25 percent)
- Change in business activity (e.g., retail to trade finance)
- Geographic risk change (country added to FATF Grey List)
- Adverse media hit (name appears in corruption investigation)
- PEP designation change (customer becomes PEP)
- Unusual transaction pattern (ATL or BTL violation)
- Law enforcement inquiry (314(a) request, subpoena, search warrant)
- New sanctions designation (customer appears on OFAC SDN list)

[REG] FinCEN CDD Rule (2016) requires banks to understand nature and purpose of relationships and update on a risk basis. [ALERT] Waiting for scheduled 3-year refresh after a material change is a control failure.

Risk-Based Prioritization for KYC Refresh

AI and machine learning can help prioritize which customers need immediate refresh versus those that can wait for scheduled review.

Factors for AI-Based Prioritization:

- Time since last refresh (older reviews prioritized higher)
- Risk tier (high-risk customers prioritized over low-risk)
- Transaction activity volume and velocity (sudden increases trigger review)
- Changes in customer behavior patterns (deviation from baseline)
- Adverse media hits (severity score and recency)
- Sanctions or PEP list changes (new matches or close matches)
- Geographic risk changes (customer's country added to monitoring list)
- Product usage changes (customer started using high-risk products)

Benefits of AI Prioritization:

- Resources focused on highest-risk customers first
- Reduced manual effort for low-risk customers
- Faster identification of risk changes
- Ability to refresh thousands of customers based on risk scoring
- Defensible prioritization for regulators

[ALERT] Prioritization methodology must be documented and defensible to regulators.

Continuous Adverse Media Monitoring

Adverse media tools automatically scrape, classify, and match negative news against customer databases.

How Adverse Media Tools Work (Technical):

- 1 Data Ingestion: Web scraping (news, government sites, court records) plus API feeds (Reuters, Bloomberg, regulatory databases)
- 2 NLP Processing: Named Entity Recognition extracts persons, organizations, locations. Sentiment analysis classifies negative vs. neutral or positive.
- 3 Entity Resolution: Matches extracted names to customer database using fuzzy logic (overcomes misspellings, middle names, initials)
- 4 Risk Scoring: Assigns severity (1-10) based on article source, crime type, conviction status, recency
- 5 Alert Generation: Creates case for compliance review if score exceeds configured threshold

Credible Sources vs. Non-Credible:

- Credible: Official gazettes, court records, major news (Reuters, AP, FT, WSJ, BBC), regulatory actions, Interpol notices
- Not credible: Unverified social media, anonymous blogs, competitor accusations, unmoderated comment sections

[FOCUS] Exam tests distinction between credible adverse media (actionable) and non-credible (not actionable alone).

[SCENARIO] CEO Named in Corruption Inquiry - No Conviction An EDD analyst discovers through OSINT that a corporate customer's CEO was named (not charged, not convicted) in a foreign parliamentary corruption inquiry 18 months ago. Separately, the customer's primary counterparty's director appears on an Interpol Red Notice. The compliance officer argues that since no conviction has occurred, the adverse media is inconclusive and no action is required.

What the Exam Tests: Reasonable suspicion, not conviction, is the standard for AML action.

How to Analyze (Exam Logic):

- ① OSINT findings from parliamentary inquiry constitute credible adverse media
- ② Conviction is NOT required for AML action (reasonable suspicion standard)
- ③ Interpol Red Notice alone justifies immediate SAR filing (international wanted person)
- ④ Findings require escalation and potential EDD, relationship reassessment
- ⑤ No conviction is not a defense for ignoring credible adverse media

[TRAP] No conviction means the adverse media is inconclusive and can be ignored.

[CORRECT] Correct: OSINT findings do not require a conviction to be actionable.

Reasonable suspicion is the standard for AML risk assessment.

Graph Theory in AML

Network analysis models accounts as nodes and transactions as edges, then calculates centrality metrics to identify suspicious patterns.

Key Centrality Metrics and AML Application:

- Degree Centrality: Number of direct connections. High degree equals many counterparties. Suspicious for money mules (many incoming small payments).
- Betweenness Centrality: Number of shortest paths passing through a node. High betweenness equals critical intermediary. Suspicious for layering accounts.
- Eigenvector Centrality: Connected to other high-centrality nodes. Suspicious for core conspiracy members or masterminds.
- PageRank (Google algorithm): Importance based on inbound connections. Finds central players in money laundering network.

Clustering Algorithms:

- Louvain community detection: Identifies groups of accounts with dense internal connections (e.g., money mule rings)
- Connected components: Accounts that transact only within a closed group (no external economic rationale)

[FOCUS] Exam expects you to know that network analysis detects patterns individual monitoring cannot see.

[SCENARIO] Network Analysis Reveals 23-Account Money Mule Ring A bank's network analysis tool identifies a cluster of 23 accounts with: (1) all opened within a 48-hour window; (2) all received small P2P transfers (\$200-\$500) from over 100 different external senders; (3) all then aggregated funds and wired to the same offshore shell company; (4) shared IP addresses (VPN through secrecy haven); (5) shared mobile phone number for verification. Individual transaction monitoring flagged zero accounts as suspicious because each account's activity appeared isolated.

What the Exam Tests: Network analysis detects coordinated patterns that individual account monitoring misses.

How to Analyze (Exam Logic):

- 1 Individual monitoring cannot see cross-account patterns
- 2 Network analysis reveals the coordinated activity across 23 accounts
- 3 The pattern is classic money mule network (layering, consolidation, offshore exit)
- 4 Shared IP addresses and phone numbers are critical indicators (tying accounts together)
- 5 Bank should file SARs on all 23 accounts
- 6 Freeze remaining funds and exit relationships

[TRAP] Individual account monitoring is sufficient; network analysis is optional. [CORRECT]
Correct: Network analysis is essential for detecting coordinated criminal networks that individual account monitoring cannot identify. The pattern requires SAR filing.

SWIFT MT Message Types

Most cross-border wires use SWIFT MT (MT103 customer transfer, MT202 interbank transfer).

Key Fields and Screening Requirements:

Field	Content	Screening Requirement
Field 50 (Ordering Customer)	Name and address of originator	Full screening against sanctions, PEP adverse media
Field 52 (Ordering Institution)	Originating bank	Sanctions screening of bank
Field 56 (Intermediary Institution)	Correspondent bank	Sanctions screening
Field 57 (Account With Institution)	Beneficiary bank	Sanctions screening
Field 59 (Beneficiary Customer)	Name and address of beneficiary	Full screening against sanctions, PEP adverse media
Field 70 (Remittance Information)	Free text payment purpose	NLP screening for suspicious keywords (e.g., discreet, cash, shell)
Field 72 (Sender to Receiver Info)	Free text instructions	Screening for evasion patterns

[ALERT] Free text fields (Field 70, 72) are often used to evade screening with misspellings or coded language. [TECH] ISO 20022 (successor to SWIFT MT) provides richer structured

How Blockchain Analytics Work

Blockchain surveillance tools map transactions on public ledgers (Bitcoin, Ethereum, etc.) to identify illicit activity.

Technical Capabilities:

- Address Clustering: Groups addresses owned by the same entity using heuristic analysis (common input ownership, change address patterns, peeling chains)
- Transaction Graph Analysis: Follows funds through multiple hops (5-10 plus hops) to trace origin or destination
- Risk Scoring: Assigns risk score (0-100) to addresses based on exposure to known illicit sources (darknet markets, mixers, ransomware wallets, sanctioned addresses)
- Real-time Screening: Alerts when customer sends or receives to or from high-risk address
- Travel Rule Compliance: Originator and beneficiary information attached to transactions (required for regulated VASPs)

Major Blockchain Analytics Vendors:

- Chainalysis: KYT (Know Your Transaction) for real-time screening, Reactor for investigation
- Elliptic: Navigator for visual investigation, Lens for real-time risk scoring
- TRM Labs: Transaction monitoring, sanctions screening, case management
- CipherTrace: (now Mastercard) Cross-border crypto intelligence

[ALERT] Privacy coins (Monero, Zcash) cannot be fully traced - many exchanges delist them entirely.

FATF Recommendation 16 (Updated 2019)

Virtual Asset Service Providers (VASPs) must share originator and beneficiary information for transfers above threshold (typically **\$1,000 USD** or EUR).

Required Information for Each Transfer:

- Originator's full name
- Originator's account number (wallet address or account reference)
- Originator's address, national ID number, or date of birth (at least one)
- Beneficiary's full name
- Beneficiary's account number (wallet address)

Originating VASP Obligations:

- Collect and verify required information before transfer
- Transmit information securely to receiving VASP
- Maintain records for at least 5 years
- Immediately freeze and report suspicious transfers

Receiving VASP Obligations:

- Obtain required information from sending VASP
- Take action if information not provided (request, delay, block, enhanced scrutiny)
- Cannot accept transfers without required information (absolute obligation)
- File SAR if information cannot be obtained and transfer is suspicious

[ALERT] Receiving VASP cannot simply ignore missing originator data. Not my problem is a violation.

[SCENARIO] VASP Receives Transfer with No Originator Information A registered VASP receives a transfer of 4.2 Bitcoin (approximately \$180,000) from another VASP with no originator or beneficiary information attached. The receiving VASP's compliance officer argues that because the customer has already passed KYC, the missing originator data is the sending VASP's problem. The customer states the funds are a personal Bitcoin investment.

What the Exam Tests: Receiving VASP obligations under the Travel Rule.

How to Analyze (Exam Logic):

- ① Receiving VASP has independent obligation to obtain required information (FATF Recommendation 16)
- ② Missing information requires follow-up action (request from sending VASP, delay transaction, enhanced scrutiny)
- ③ \$180,000 transfer is well above typical \$1,000 threshold
- ④ Customer's KYC at receiving VASP does NOT substitute for originator data (different person)
- ⑤ If sending VASP cannot provide information, consider blocking and SAR filing

[TRAP] The Travel Rule imposes obligations only on the originating VASP. [CORRECT]
Correct: The receiving VASP has an obligation to obtain originator and beneficiary information. If not provided, the receiving VASP must take follow-up action, including enhanced scrutiny and potential SAR filing.

Supervised Learning (Most Common in AML)

Model learns from labeled historical data (suspicious vs. legitimate transactions).

Examples:

- Random Forest, XGBoost, Gradient Boosting (tree-based models - good explainability)
- Logistic Regression (simple, very explainable, good baseline)
- Neural Networks / Deep Learning (powerful but black box - requires XAI)

Pros: High accuracy if labeled data available, can optimize for recall (catching bad guys) **Cons:** Requires large labeled dataset (SARs), may not detect new typologies

Unsupervised Learning (Anomaly Detection)

Model finds patterns without labels - flags outliers as potential anomalies.

Examples:

- Autoencoders (neural networks that reconstruct input, high reconstruction error equals anomaly)
- Isolation Forests (random forest that isolates anomalies)
- One-Class SVM (learns boundary around normal data)
- K-means clustering (distant points from centroids equals anomalies)

Pros: Can detect novel typologies, no labeled data needed **Cons:** Very high false positives (often 90 percent plus), hard to validate, hard to explain

[FOCUS] Hybrid approach: supervised for known typologies, unsupervised for novel anomalies.

Regulatory Requirements for Model Validation

All AML models (transaction monitoring, sanctions screening, fraud detection) are subject to model risk management requirements under OCC 2011-12 and SR 11-7.

Key MRM Components:

- 1 Model Inventory: All models documented, owners assigned, risk tier (high, medium, low)
- 2 Model Development Documentation: Theoretical basis, assumptions, limitations, data sources
- 3 Independent Validation: Before deployment and periodically after (annually for high-risk models)
- 4 Performance Monitoring: Ongoing tracking of precision, recall, false positive rate, drift
- 5 Model Governance: Policies, procedures, approval authorities, escalation path

Validator Independence Requirements:

- Validator cannot be involved in model development
- Validator must report functionally to independent risk management (not to model development)
- External validation for high-risk models (e.g., sanctions screening)

Validation Report Must Address:

- Conceptual soundness (does model logic make sense for AML?)
- Data quality (is input data complete and accurate?)
- Outcomes analysis (precision, recall, ATL, BTL)
- Benchmarking (comparison to alternative models)
- Limitations and compensating controls

[ALERT] A model that cannot be validated (black box AI) is a regulatory violation.

Why ML Models Degrade Over Time

Models are trained on historical data. When the real world changes, model performance degrades. This is called model drift.

Concept Drift (Most Dangerous):

- The relationship between input features and target variable changes
- Example: Criminal typology shifts from cash structuring to cryptocurrency layering. Old model learned patterns of cash behavior, no longer relevant.
- Detection: Monitor recall rate (capture of new SARs). Decline indicates concept drift.
- Remediation: Retrain model with new data including new typology.

Data Drift (Feature Distribution Changes):

- Input data distribution changes, but relationship remains same
- Example: Customer transaction volume increases 180 percent after product launch. Model trained on lower volumes now sees many false positives.
- Detection: Monitor feature distributions (KS test, Population Stability Index)
- Remediation: Recalibrate thresholds or retrain with new data

Regulatory Expectation:

- Annual model validation (minimum)
- Trigger-based validation after material changes to products, customer base, or typologies

[FOCUS] Exam scenario: model not recalibrated for 3.5 years despite new products and typologies - material deficiency.

Why Explainability Matters

Regulators require that analysts understand why a transaction was flagged. SAR narratives must include rationale. Black box AI is unacceptable.

SHAP (SHapley Additive exPlanations):

- Game-theoretic approach: assigns each feature an importance value for the prediction
- Output example: Transaction amount \$25,000 contributed +0.8 to risk score; counterparty high-risk jurisdiction contributed +0.5; total 1.3 exceeds threshold 1.0
- Analysts can see which features drove the alert
- Consistent and locally accurate

LIME (Local Interpretable Model-agnostic Explanations):

- Creates a simple, interpretable model (e.g., linear regression) locally around the prediction
- Explains individual predictions, not global model behavior
- Works with any black box model
- Faster than SHAP but less stable

Counterfactual Explanations:

- If the transaction amount had been \$19,000 instead of \$25,000, it would not have been flagged
- Useful for customer disputes and internal understanding

[ALERT] Black box AI with no explainability will be rejected by regulators regardless of accuracy.

How Autoencoders Detect Anomalies

Neural network trained to reconstruct normal transactions. High reconstruction error equals anomaly (potential suspicious activity).

Technical Architecture:

- Encoder: Compresses input (e.g., 100 transaction features) into lower-dimensional representation (e.g., 10 latent variables)
- Decoder: Reconstructs original input from latent representation
- Training: Minimize reconstruction error on normal transactions only

Inference (Monitoring):

- Feed transaction through autoencoder
- Calculate Mean Squared Error (MSE) between input and reconstruction
- If MSE greater than threshold, flag as anomaly

Pros and Cons:

- Pro: No labeled data required, can detect novel typologies
- Con: Very high false positives (90 percent plus)
- Con: Hard to explain why transaction was flagged
- Con: Requires threshold tuning (challenging without labels)

[FOCUS] Exam tests that unsupervised models still require independent validation, despite being supplemental.

Key Performance Metrics for AML Models

Regulators expect banks to track and report these metrics regularly.

Metric	Formula	AML Interpretation
Precision	$TP / (TP + FP)$	Of all alerts, how many were true positives? Low precision equals many false positives.
Recall (Sensitivity)	$TP / (TP + FN)$	Of all suspicious activity, how many generated alerts? Low recall equals missed suspicious activity.
F1 Score	$2 * (Precision * Recall) / (Precision + Recall)$	Harmonic mean - balances precision and recall.
Specificity	$TN / (TN + FP)$	Of all legitimate activity, how many did NOT generate alerts? Low specificity equals many false positives.
AUC-ROC	Area Under Receiver Operating Characteristic Curve	Model's ability to distinguish suspicious from legitimate (0.5 equals random, 1.0 equals perfect).

Target Ranges for AML (Typical Industry Benchmarks):

- Recall: Greater than 80 percent (regulators prioritize detection)
- Precision: 10-30 percent (many false positives accepted if recall is high)

AI Tools to Support AML Investigators

Beyond alert generation, AI and ML can significantly enhance the investigation workflow.

AI-Powered Investigation Tools:

- Automated Data Aggregation: Pulls KYC, transactions, sanctions hits, adverse media into single case file (minutes versus hours)
- Entity Resolution: Connects related accounts, addresses, phone numbers across systems
- Risk Scoring of Alerts: Prioritizes highest-risk alerts for investigator review
- Automated Narrative Generation: Drafts SAR narratives from structured case data (analyst reviews and edits - not auto-filed)
- Link Analysis Visualization: Automatically maps relationships between entities
- Predictive Case Closure: Suggests likely false positive based on historical patterns (with human validation)

Key Exam Distinction:

- AI can AUTOMATE data collection and prioritization
- AI should NOT replace investigator judgment for SAR decisions
- Investigators must always review and validate AI suggestions
- A SAR filed solely on AI recommendation without human analysis is a regulatory risk

[ALERT] A SAR filed solely on an AI recommendation without human analysis is unacceptable.

Core Functionality for AML Investigators

Case management systems (CMS) support the investigation workflow from alert to SAR filing.

Must-Have CMS Capabilities:

- Alert Intake: Auto-creation of cases from monitoring system alerts, with priority scoring (high, medium, low)
- Data Aggregation: Automatically pull KYC, transactions, sanctions hits, adverse media, network links into single case file
- Link Analysis Visualization: Graph display of entity relationships, transaction flows
- Timeline Analysis: Chronological view of customer activity (list view plus graph)
- Document Management: Store investigation notes, evidence, screenshots, emails
- SAR Generation: Auto-populate SAR or STR forms from case data (populated by investigator, not auto-filed)
- Audit Trail: Log all actions (who viewed what, when, what decisions made) - immutable
- Collaboration Tools: Notes, tasks, assignments, supervisor approval workflow
- Reporting Dashboards: Management view of queue size, aging, SAR volume, analyst performance

[ALERT] Audit trail is mandatory - regulators will request logs of who accessed which cases.

Credible OSINT Sources (Actionable for AML)

Only information from authoritative, verifiable sources should be used in AML investigations.

Credible Sources by Category:

- Government Official Sources: Sanctions lists (OFAC, UN, EU, UK HMT), corporate registries (Companies House, SEC EDGAR), court records (PACER), government gazettes
- Law Enforcement: Interpol Red Notices (www.interpol.int), FBI Most Wanted, Europol wanted lists
- Regulatory: FinCEN enforcement actions, SEC enforcement, FCA fines, OCC consent orders
- Investigative Journalism: ICIJ (Offshore Leaks, Panama Papers, Pandora Papers), OCCRP, Bellingcat, Reuters Investigates
- Major News: Reuters, Bloomberg, Financial Times, Associated Press, Wall Street Journal, BBC
- Commercial Databases: Dun and Bradstreet, LexisNexis, Dow Jones Factiva, Sayari

Non-Credible Sources (Not Actionable Alone):

- Unverified social media (Twitter, Facebook, LinkedIn without verification)
- Anonymous blogs (Medium, WordPress with no author attribution)
- Unmoderated forums (Reddit, 4chan)
- Competitor allegations without evidence
- Personal websites with no attribution

[FOCUS] Exam tests distinction between credible and non-credible OSINT sources.

Balancing AML Obligations and Privacy Rights

Technology can help comply with both AML and privacy laws (GDPR, CCPA, etc.).

PETs Applicable to AML:

- Data Minimization: Collect only data required for AML (not extraneous personal data). GDPR Article 5(1)(c).
- Anonymization: Remove all personal identifiers where not needed (e.g., aggregated reports). Cannot be reversed.
- Pseudonymization: Replace identifiers with tokens (e.g., customer ID replaced with token). Reversible with key. GDPR encourages pseudonymization.
- Encryption: Protect data at rest (AES-256) and in transit (TLS 1.3). Required for data protection laws.
- Access Controls: Role-based access (RBAC) - investigators see only data needed for their cases. Log all access.
- Audit Logs: Track all access to sensitive AML data. Required for breach notification.
- Secure Data Sharing: Encrypted channels for 314(b) sharing, FIU reporting (GoAML, secure FTP).

[ALERT] AML obligations override privacy rights for required data retention (e.g., 5-year recordkeeping).

[SCENARIO] Bank Receives Right to Erasure Request for SAR Customer A European bank receives a GDPR right to erasure request from a customer demanding deletion of all personal data, including KYC documents and transaction records. The customer was the subject of a SAR filed 18 months ago. The Data Privacy Officer argues GDPR requires deletion. The AML Officer argues AML recordkeeping requires retention (minimum 5 years).

What the Exam Tests: GDPR exception for legal obligations (AML retention).

How to Analyze (Exam Logic):

- 1 GDPR Article 17(3)(b) exempts data retention required by Union or Member State law
- 2 AML directives (4AMLD, 5AMLD) require 5-year retention of records
- 3 Bank can lawfully refuse to delete AML-required records
- 4 SAR confidentiality (non-tipping off) also prohibits acknowledging SAR existence to customer

[TRAP] GDPR's right to erasure is absolute and overrides all other laws. [CORRECT]
Correct: AML retention requirements are a legal exception to GDPR erasure rights. The bank may refuse deletion for records it is required to retain.

Evaluating AML Technology Vendors

Selecting the right tool requires balancing multiple factors; cheapest is rarely best.

Key Selection Criteria with Sub-Questions:

- Risk Alignment: Does the tool address your specific ML or TF risks (trade finance, crypto, correspondent banking, etc.)? Request vendor typology coverage list.
- Regulatory Acceptance: Has the vendor been examined by regulators (OCC, FinCEN, FCA)? Do peer institutions use it? Any public enforcement actions against vendor?
- Integration Complexity: APIs available (REST, GraphQL)? Data format compatibility with core banking system? Proof of concept with your data required.
- Performance Metrics: Request vendor's false positive rate, recall rate, precision on independent test data (not vendor's own marketing numbers).
- Explainability: Can the tool explain WHY it flagged a transaction? Required for AI models (SHAP, LIME, rule extraction).
- Total Cost of Ownership (TCO): License fees plus implementation plus integration plus training plus ongoing maintenance plus hardware or cloud costs.
- Vendor Stability: Financial health, support responsiveness, update frequency, data privacy compliance (GDPR, CCPA).
- Scalability: Can it handle 2x or 5x current transaction volume without performance degradation? Stress test results?

[ALERT] Failure to conduct proper due diligence on a vendor is a regulatory deficiency.

Integration Risk Points (Exam Scenarios)

A tool is only as good as its data feeds. Poor integration equals poor detection.

Systems That Must Integrate:

- Core Banking System: Customer master, account balances, transaction history
- Payment Systems: SWIFT, ACH, Fedwire, SEPA, crypto wallets (via API)
- CRM: Customer contact info, relationship manager assignments
- Case Management: Workflow integration (alert to case to SAR)
- Data Lake or Warehouse: Historical data for model training and validation
- Sanctions Lists: Real-time API feeds for list updates (avoid manual downloads)

Integration Risk Points (Common Exam Scenarios):

- Data format mismatches: CSV vs. JSON vs. XML vs. proprietary formats
- Data latency: Transaction at 9:00 AM, monitoring system sees it at 9:00 PM (criminal window)
- Silent feed failures: No error message, data just missing (most dangerous)
- API rate limiting: Vendor caps queries at 1,000 per second, but bank has 5,000 per second equals queued or dropped transactions
- Version compatibility: Core system upgrade breaks integration for weeks

Best Practices:

- Always require a proof of concept (POC) with your actual data
- Test data feeds thoroughly before go-live (including failure scenarios)
- Establish reconciliation between source and target
- Document integration architecture and data flows

[ALERT] API rate limiting is a common hidden risk - test at peak volume.

Balancing Two Competing Priorities

Regulators prioritize effectiveness (catching bad activity) over efficiency (cost per alert).

Measuring Operational Effectiveness (Regulator Focus):

- False negative rate (missed suspicious activity) - should be less than 5 percent
- SAR quality (actionable intelligence for law enforcement) - percentage of SARs that result in investigation or prosecution
- Investigation timeliness (alerts reviewed within target timeframes) - e.g., 48 hours for high-priority alerts
- Alert-to-SAR conversion rate (meaningful alerts versus noise) - 2-5 percent is typical
- Audit findings - fewer findings indicate better controls
- Back-testing results - historical SAR capture rate

Measuring Operational Efficiency (Bank Management Focus):

- Cost per alert reviewed (typical \$25-\$75)
- Time per investigation (hours per case)
- False positive rate (higher equals less efficient)
- Analyst utilization rate (percentage of time on productive investigation)
- SAR filing rate relative to peer institutions (too low or too high both scrutinized)

[ALERT] Efficiency improvements that increase false negatives (e.g., raising thresholds arbitrarily) are unacceptable.

Aligning Investment with Risk Assessment

The risk-based approach means investing most heavily where risk is highest.

High-Risk Areas Requiring More Investment:

- Correspondent Banking (highest risk): Enhanced due diligence (Wolfsberg CBDDQ), on-site inspections, dedicated monitoring team, automated screening of nested accounts
- Private Banking and Wealth Management (PEP risk): Enhanced CDD, source of wealth verification, senior management approval, relationship manager oversight
- Trade Finance (TBML vulnerability): Automated invoice matching, country risk scoring, counterparty screening, dedicated TBML analysts
- Virtual Assets (emerging typologies): Blockchain analytics (Chainalysis or Elliptic), Travel Rule compliance, mixer and darknet monitoring
- Cross-Border Payments (jurisdictional risk): Enhanced payment screening, jurisdiction risk scoring, correspondent bank restrictions
- Cash-Intensive Businesses (structuring risk): Aggregated cash reporting, geographic profiling, branch-level monitoring

Lower-Risk Areas for Lighter Investment (Simplified Due Diligence):

- Domestic retail payroll accounts (low transaction velocity, predictable patterns)
- Low-balance consumer accounts (less than \$5,000 balance)
- Government benefit disbursement accounts (limited usage)
- Regulated public companies (subject to disclosure requirements)

[ALERT] Applying the same resources to all customers violates the risk-based approach.

- 1 Silent data failure equals monitoring gap
- 2 Reconciliation controls prevent undetected data loss
- 3 Fuzzy logic required for sanctions screening
- 4 False negatives worse than false positives
- 5 Model drift requires regular recalibration
- 6 Explainability required for AI models (XAI)
- 7 E-KYC requires liveness detection
- 8 Network analysis detects money mule rings
- 9 Travel Rule applies to both sending and receiving VASPs
- 10 Adverse media does NOT require conviction
- 11 Data quality is compliance responsibility
- 12 Perpetual KYC is superior to periodic refresh
- 13 Trigger-based refresh required for material changes
- 14 ATL and BTL testing validates scenario effectiveness
- 15 Rules-based plus ML hybrid is best practice
- 16 Unsupervised models still require validation
- 17 SWIFT fields requiring screening: 50, 52, 56, 57, 59, 70
- 18 Blockchain analytics required for VASPs
- 19 Privacy coins and mixers require EDD
- 20 Receiving VASP cannot ignore missing Travel Rule data
- 21 GDPR has AML retention exception (Article 17(3)(b))
- 22 OSINT must use credible sources only
- 23 Tool selection must consider integration and scalability
- 24 Effectiveness prioritized over efficiency
- 25 Risk-based approach drives resource allocation

- 26 Model risk management requires independent validation
- 27 Sanctions screening requires fuzzy logic, not exact matching
- 28 Over-filtering increases false negatives
- 29 Scenario coverage must address all typologies
- 30 Investigation tools require audit trails
- 31 Biometrics alone insufficient without liveness
- 32 MRZ validation for identity documents
- 33 Hash totals for data reconciliation
- 34 Concept drift versus data drift
- 35 SHAP and LIME for model explainability
- 36 Precision, recall, F1, AUC-ROC metrics
- 37 Autoencoders for anomaly detection
- 38 High betweenness centrality equals layering account
- 39 FATF digital ID assurance levels (low, medium, high)
- 40 Silent feed failures are most dangerous
- 41 NULL Customer ID equals unlinked transactions
- 42 API rate limiting causes missed transactions
- 43 Proof of concept required before vendor contract
- 44 Analyst fatigue from high false positives
- 45 Board reporting on data quality metrics
- 46 Non-tipping off for SAR customers
- 47 Interpol Red Notice equals immediate SAR consideration
- 48 Correspondent banking highest risk
- 49 Nested account activity requires EDD
- 50 Shell bank prohibition (USA PATRIOT Act)

- 34 percent missing data for 14 months -¿ Data failure
- NULL Customer ID on transactions -¿ Unlinked transactions
- No reconciliation controls -¿ Undetected gaps
- 77 percent false negative rate -¿ Material deficiency
- No recalibration for 3.5 years -¿ Model drift
- Black box AI with no explainability -¿ Governance failure
- Exact-string matching only -¿ Sanctions screening failure
- No liveness detection -¿ Spoofing vulnerability
- No adverse media review -¿ Missed risk indicators
- No network analysis -¿ Missed mule rings
- Missing Travel Rule data accepted -¿ VASP violation
- No ATL or BTL testing -¿ Unvalidated scenarios
- Only annual refresh after material changes -¿ Control gap
- Same onboarding for all customers -¿ RBA violation
- No independent model validation -¿ MRM failure
- API rate limiting untested -¿ Transaction loss
- No hash reconciliation -¿ Data corruption undetected
- 24+ hour data latency -¿ Criminal window

- Domain D is 20 percent of CAMS exam - do not underestimate
- Data quality is a COMPLIANCE responsibility, not just IT
- Silent data failures (no error messages) are the most dangerous
- FALSE NEGATIVES are worse than false positives (regulator priority)
- Fuzzy logic is REQUIRED for sanctions screening (exact matching insufficient)
- ML models require explainability (SHAP or LIME) and ongoing validation
- Model drift requires regular recalibration (annual minimum)
- Travel Rule applies to BOTH sending and receiving VASPs
- E-KYC without liveness detection can be spoofed (deepfakes)
- Adverse media findings do NOT require conviction (reasonable suspicion)
- Network analysis detects patterns individual monitoring misses
- GDPR has an AML retention exception (Article 17(3)(b))
- Credible OSINT sources: government, courts, reputable journalism
- Privacy coins and mixers require EDD (high risk)
- Effectiveness is greater than efficiency (regulator priority)
- Risk-based approach drives resource allocation
- Always require a proof of concept (POC) before signing vendor contract
- Test reconciliation controls and API rate limits at peak volume

[CORRECT] Good luck on the exam!

Core Definition

Transaction monitoring is the primary detective control for identifying suspicious activity after customer onboarding. It continuously screens transactions for patterns indicative of money laundering or terrorist financing.

Key Components of Transaction Monitoring:

- Data ingestion from core banking and payment systems
- Rules-based scenarios and machine learning models
- Customer segmentation for risk-appropriate thresholds
- Alert generation and prioritization
- Case management and investigation workflow
- SAR/STR filing and documentation

[FOCUS] Transaction monitoring is the largest operational investment for most banks and the most frequently cited deficiency in regulatory enforcement actions.

Standard Data Flow

Core Systems -> Data Aggregation -> Scenario Execution -> Alert Generation -> Case Management -> Investigation -> SAR Filing

System Components in Detail:

- Data Ingestion Layer: Pulls from core banking, payments, CRM, trade finance. Handles batch (nightly) and real-time (Kafka, RabbitMQ) feeds.
- Data Transformation Layer: Normalizes formats, maps fields, enriches with customer risk rating and segmentation data.
- Scenario Engine: Executes pre-defined rules (SQL, Drools) or ML models. Must scale to millions of transactions daily.
- Alert Generation: Creates case in case management system with priority scoring (high, medium, low).
- Case Management: Workflow for investigation, evidence collection, narrative writing, approval.
- Reporting Engine: Files SAR/STR to FIU, generates management dashboards.

[ALERT] Data latency at any point creates a window for criminals to move funds before detection.

Deterministic Logic

Rules-based monitoring uses pre-defined, deterministic logic written by analysts to flag specific transaction patterns.

Example Rule Structures:

- IF cash deposits in rolling 30 days $\geq$ \$9,500 AND $\leq$ \$10,000 AND number of deposits $\geq$ 5 THEN generate alert
- IF wire transfer to high-risk jurisdiction AND amount $\geq$ \$25,000 AND no prior history THEN generate alert
- IF rapid movement (funds in and out within 24 hours) AND amount $\geq$ \$50,000 THEN generate alert

Advantages of Rules-Based:

- Completely explainable and auditable
- Low false positive rate when well-tuned (5-10 percent)
- Simple to implement with SQL or rules engines
- No model drift over time
- Low computational requirements

Disadvantages of Rules-Based:

- Misses new or evolving typologies
- Requires constant manual rule updates
- Criminals can learn and game the rules
- Cannot detect complex patterns across multiple dimensions

[FOCUS] The exam tests that rules-based systems must be updated regularly as typologies evolve.

Why Segmentation is Critical

Applying the same monitoring rules to all customers creates excessive false positives for low-risk customers and false negatives for high-risk customers.

Typical Segmentation Dimensions:

- Customer Risk Tier: Low, Medium, High, PEP
- Product Type: Deposit accounts, loans, trade finance, crypto
- Geographic Risk: Low, Medium, High, Embargoed
- Channel: Branch, online, mobile, ATM
- Transaction Type: Cash, wire, ACH, check, crypto
- Business Line: Retail, Commercial, Private Banking, Correspondent

Segmentation Impact on Thresholds:

Customer Type	Alert Threshold	Review Priority
Low Risk Retail	Higher threshold	Lower priority
Medium Risk Retail	Standard threshold	Standard priority
High Risk PEP	Lower threshold	High priority
Correspondent Bank	Lowest threshold	Highest priority

[ALERT] Failure to segment customers by risk is a violation of the risk-based approach.

How Segmentation Changes Monitoring Behavior

The same transaction amount triggers different responses based on customer segment.

Example: \$15,000 Wire Transfer to High-Risk Country

- Low-risk retail customer: No alert (threshold is \$25,000)
- Medium-risk retail customer: Low priority alert (threshold is \$10,000)
- High-risk customer: High priority alert (threshold is \$5,000)
- PEP customer: Immediate block pending review (threshold is \$1,000)

Segmentation Data Sources:

- Customer risk rating from onboarding and periodic review
- Transaction history and velocity patterns
- Product usage and changes over time
- Geographic exposure and counterparty risk
- Adverse media and PEP status

Segmentation Maintenance:

- Segments must be reviewed at least annually
- Customers can move between segments based on behavior
- Automated re-segmentation based on trigger events

[FOCUS] Segmentation is not a one-time exercise. Customers change risk profiles over time.

Required Scenario Coverage

Every money laundering typology relevant to your institution must have corresponding monitoring scenarios.

Common Typologies and Detection Scenarios:

Typology	Detection Scenario	Key Indicators
Structuring	Cash aggregation just below CTR threshold	Multiple deposits, multiple branches, multiple tellers
Layering	Rapid movement through multiple accounts	Funds in and out within 24 hours, 3+ hops
Trade-Based ML	Invoice-payment mismatch	Round-dollar amounts, commodity mismatch
Shell Companies	No operating expenses but high volume	No payroll, no rent, no utilities
PEP Activity	Large unexplained transfers	No source of funds documentation
NPO/Terrorist Financing	Rapid cash out to conflict zone	Donations from unrelated parties
Cybercrime	Payment to known ransomware wallet	Darknet market exposure
Human Trafficking	Small payments to controller account	Hotel and travel purchases

How to Identify Coverage Gaps

Regular gap analysis ensures scenarios remain aligned with your risk assessment.

Gap Analysis Methodology:

- 1 Review current risk assessment for identified typologies
- 2 Map each typology to existing monitoring scenarios
- 3 Identify typologies with no or partial coverage
- 4 Prioritize gap remediation based on risk level
- 5 Develop and test new scenarios for gaps

Common Coverage Gaps (Exam Scenarios):

- Trade-based money laundering scenarios missing when institution offers trade finance
- Cryptocurrency scenarios missing when institution allows crypto transactions
- Correspondent banking nested account scenarios missing
- Human trafficking indicators not configured
- Rapid layering detection missing (funds in and out same day)

Regulatory Expectation:

- Gap analysis performed at least annually
- Documentation of coverage decisions
- Remediation plan for identified gaps
- Board reporting on significant gaps

[FOCUS] The exam tests that scenario coverage must be based on the institution's risk assessment.

What Thresholds Control

Thresholds determine which transactions generate alerts and which are filtered out.

Types of Thresholds:

- Monetary Thresholds: Dollar amounts (e.g., alert on transactions $\geq$ \$10,000)
- Velocity Thresholds: Frequency within time period (e.g., 5+ deposits in 30 days)
- Count Thresholds: Number of transactions (e.g., 10+ wires to same beneficiary)
- Percentage Thresholds: Variance from baseline (e.g., 200% increase from average)
- Scoring Thresholds: Risk score from ML model (e.g., score $\geq$ 0.85)

Factors Influencing Threshold Setting:

- Customer risk tier (lower thresholds for higher risk)
- Product type (lower thresholds for high-risk products)
- Geographic risk (lower thresholds for high-risk jurisdictions)
- Historical false positive rates (adjust to optimize)
- Regulatory expectations (specific guidance may exist)
- Operational capacity (can you review all alerts?)

[ALERT] Thresholds set too high create false negatives (missed suspicious activity).

Data-Driven Threshold Calibration

Thresholds must be set based on data analysis, not arbitrary decisions.

Calibration Process:

- 1 Analyze historical transaction data by segment
- 2 Identify normal patterns and outliers
- 3 Run historical SARs through candidate thresholds
- 4 Calculate capture rate (ATL) at each threshold
- 5 Calculate false positive rate (BTL) at each threshold
- 6 Select threshold balancing detection and operational load

Example Calibration Analysis:

Threshold	Expected month	Alerts/	Capture Rate (ATL)	False Positive Rate
\$5,000	12,000		98%	35%
\$10,000	6,500		94%	18%
\$15,000	3,200		87%	9%
\$20,000	1,800		76%	5%

Decision Factors:

- Regulator priority: higher capture rate (even with more alerts)
- Operational capacity: can you review 6,500 alerts per month?
- Risk tolerance: is 87

[FOCUS] The exam tests that threshold changes must be data-driven and validated.

[SCENARIO] Compliance Director Raises All Thresholds by 250 Percent A bank generates 8,000 alerts per month. 96 percent are false positives. The compliance director, under pressure to reduce costs, orders all thresholds raised by 250 percent across all scenarios. The analytics team warns of increased false negatives. The director states: We cannot afford to review 8,000 alerts per month. Any missed activity is acceptable as long as we still file some SARs. Regulators later find criminal structuring below the new thresholds went undetected for 18 months.

Why This is a Violation:

- 1 250 percent increase is arbitrary - no data analysis performed
- 2 Director prioritized cost over effectiveness (inverse of regulatory priority)
- 3 Statement any missed activity is acceptable is willful non-compliance
- 4 No consideration of risk-based approach (same increase for all segments)
- 5 No ATL/BTL testing to validate new thresholds

Proper Approach:

- 1 Analyze false positive root causes (improve scenarios, don't just raise thresholds)
- 2 Segment customers (lower thresholds for high-risk, higher for low-risk)
- 3 Test threshold changes with ATL/BTL before implementation
- 4 Monitor false negative rate after changes
- 5 Document all threshold decisions with supporting data

[TRAP] The director is correctly managing operational efficiency under the risk-based approach. [CORRECT] Correct: Raising thresholds without data analysis and validation creates unacceptable false negative risk.

ATL Testing Validates Scenario Effectiveness

ATL testing proves that transactions which **SHOULD** generate alerts actually do.

Detailed Methodology:

- 1 Compile historical confirmed suspicious cases (SARs filed, EDD findings)
- 2 Ensure cases represent all relevant typologies
- 3 Run these cases through current production monitoring scenarios
- 4 Calculate capture rate = (cases that generated alert) / (total cases)
- 5 Expected capture rate: 90-100 percent for well-tuned scenarios

Low Capture Rate Analysis (Below 90 percent):

- Thresholds too high (over-filtering) - most common cause
- Scenario logic too narrow - missing variations of typology
- Data quality issues - missing transactions or fields
- Typology has evolved - scenario needs update
- Wrong customer segmentation - rules don't apply to this segment

Regulatory Expectation:

- ATL testing at least annually
- Material changes trigger interim testing
- Results documented and presented to management
- Remediation required for out-of-tolerance results

[ALERT] A 77 percent capture rate (23 percent false negative) on historical SARs is a material deficiency.

Example: Structuring Scenario ATL Test

Testing a scenario designed to detect cash structuring just below CTR threshold.

Test Data Set:

- 100 historical SARs for cash structuring
- Each case involved 5-10 deposits of \$8,000-\$9,900 within 30 days
- Across multiple branches and tellers

Run Through Current Scenario:

- Scenario logic: Aggregate cash deposits $\geq$ \$10,000 within rolling 30 days
- Current threshold: 8 or more deposits triggers alert

Results:

- 82 of 100 cases generated alerts (82 percent capture rate)
- 18 cases missed (18 percent false negative rate)

Root Cause Analysis:

- Missed cases had only 6-7 deposits (below 8 threshold)
- Criminals adapted to 8-deposit threshold

Remediation:

- Lower threshold to 5 deposits
- Add secondary indicators (multiple branches, multiple tellers)
- Re-test: 97 percent capture rate achieved

[FOCUS] ATL testing revealed that criminals adapted to the threshold. Scenarios must evolve.

BTL Testing Validates Scenario Specificity

BTL testing proves that transactions which SHOULD NOT generate alerts do not.

Detailed Methodology:

- 1 Identify known legitimate, low-risk transactions
- 2 Examples: payroll deposits, utility payments, mortgage payments
- 3 Run these transactions through current monitoring scenarios
- 4 Calculate false positive rate = (alerts generated) / (total test transactions)
- 5 Expected false positive rate: 0-10 percent for well-tuned scenarios

High False Positive Rate Analysis (Above 10 percent):

- Thresholds too low (under-filtering) - too sensitive
- Scenario logic too broad (over-inclusive)
- Customer segmentation issues (same rules for different risk tiers)
- Data quality issues (corrupted fields causing false matches)
- Normal behavior incorrectly classified as suspicious

Consequences of High False Positives:

- Analyst fatigue - reviewers become desensitized
- Operational cost - each false positive costs \$25-\$75
- Legitimate customer friction - delayed payments, frozen accounts
- True positives may be missed in the noise

[FOCUS] BTL testing is often overlooked by banks - exam tests whether you know it is required.

Example: Wire Transfer Scenario BTL Test

Testing a scenario designed to detect large wires to high-risk jurisdictions.

Test Data Set:

- 500 legitimate, low-risk customer transactions
- Payroll deposits, utility bills, mortgage payments
- All to low-risk jurisdictions (US, UK, Canada, EU)
- All amounts between \$100-\$5,000

Scenario Being Tested:

- Alert on any wire transfer $\geq$ \$2,500 to any jurisdiction
- No customer segmentation applied

Results:

- 85 of 500 transactions generated alerts (17 percent false positive rate)
- Legitimate wires $\geq$ \$2,500 to low-risk jurisdictions flagged

Root Cause:

- Scenario doesn't consider jurisdiction risk
- No segmentation by customer risk tier
- Threshold too low for legitimate business wires

Remediation:

- Apply tiered thresholds by jurisdiction risk
- High-risk: \$1,000 threshold
- Medium-risk: \$10,000 threshold
- Low-risk: \$25,000 threshold
- Re-test: 2 percent false positive rate achieved

[ALERT] BTL testing identified that jurisdiction risk must be incorporated into threshold setting.

Balancing Detection and Efficiency

ATL and BTL testing together provide a complete picture of scenario performance.

Performance Quadrants:

Quadrant	ATL Result	BTL Result
Ideal	High capture rate (90%+)	Low false positive rate ($\leq 10\%$)
Over-Filtered	Low capture rate ($\leq 90\%$)	Low false positive rate ($\leq 10\%$)
Under-Filtered	High capture rate (90%+)	High false positive rate ($\geq 10\%$)
Poor Design	Low capture rate ($\leq 90\%$)	High false positive rate ($\geq 10\%$)

Remediation by Quadrant:

- Over-Filtered: Lower thresholds, broaden scenario logic
- Under-Filtered: Raise thresholds, narrow scenario logic, improve segmentation
- Poor Design: Complete scenario rewrite, reconsider typology approach

Testing Frequency:

- Full ATL/BTL testing: At least annually
- Trigger-based testing: After any material change to scenario, threshold, or typology
- Continuous monitoring: Track capture rate and false positive rate monthly

[FOCUS] The exam tests that both ATL and BTL are required - not just one or the other.

Regulatory Requirements for Model Validation

All AML models (transaction monitoring, sanctions screening, fraud detection) are subject to model risk management under OCC 2011-12 and Federal Reserve SR 11-7.

Key MRM Components:

- 1 Model Inventory: All models documented, owners assigned, risk tier (high, medium, low)
- 2 Model Development Documentation: Theoretical basis, assumptions, limitations, data sources
- 3 Independent Validation: Before deployment and periodically after (annually for high-risk)
- 4 Performance Monitoring: Ongoing tracking of precision, recall, false positive rate, drift
- 5 Model Governance: Policies, procedures, approval authorities, escalation path

Validator Independence Requirements:

- Validator cannot be involved in model development
- Validator must report functionally to independent risk management
- External validation for high-risk models (e.g., sanctions screening)

[ALERT] A model that cannot be validated (black box AI) is a regulatory violation.

What Model Validation Must Address

A complete validation report answers these specific questions.

Validation Scope:

- Conceptual Soundness: Does the model logic make sense for AML detection? Are assumptions reasonable?
- Data Quality: Is input data complete, accurate, and timely? Are there data gaps?
- Outcomes Analysis: What are precision, recall, ATL capture rate, BTL false positive rate?
- Benchmarking: How does this model compare to alternative approaches?
- Limitations and Compensating Controls: What can't the model detect? What other controls fill gaps?

Validation Frequency by Risk Tier:

Risk Tier	Full Validation	Ongoing Monitoring
High Risk	Annually	Quarterly performance review
Medium Risk	Every 2 years	Semi-annual performance review
Low Risk	Every 3 years	Annual performance review

[FOCUS] Transaction monitoring models are typically classified as high or medium risk.

Handling Validation Deficiencies

Finding a problem is not enough. There must be a documented remediation process.

Severity Classifications:

- Critical Finding: Material deficiency requiring immediate action. Model may need to be suspended.
- Major Finding: Significant deficiency with defined remediation timeline (30-90 days).
- Minor Finding: Improvement opportunity with longer remediation timeline (6-12 months).
- Observation: Suggestion for enhancement, no formal remediation required.

Remediation Requirements:

- Written remediation plan for each finding
- Assigned owner and due date
- Regular status updates to model governance committee
- Evidence of remediation (re-testing results)
- Closure approval by independent validator

Common Validation Findings (Exam Scenarios):

- Model drift - performance degraded without recalibration
- Data quality issues - incomplete or inaccurate input data
- Thresholds not calibrated - arbitrary values without ATL/BTL
- Segmentation inadequate - same rules for all customers
- Documentation missing - cannot explain model decisions

[ALERT] Unremediated validation findings are a regulatory enforcement action waiting to happen.

Continuous Improvement Process

Scenario tuning is not a one-time event. It requires ongoing monitoring and adjustment.

The Calibration Cycle:

- 1 Monitor: Track alert volume, false positive rate, capture rate
- 2 Analyze: Review sample of alerts, identify patterns
- 3 Adjust: Modify thresholds, logic, or segmentation
- 4 Validate: Run ATL/BTL testing on changes
- 5 Deploy: Implement changes in production
- 6 Repeat: Continue monitoring after deployment

Tuning Levers:

- Threshold Values: Raise or lower monetary, velocity, or count thresholds
- Logic Operators: Add AND/OR conditions to narrow or broaden
- Time Windows: Expand or contract rolling periods
- Segmentation: Apply different rules to different customer types
- Exclusions: Remove known false positive patterns (e.g., internal transfers)

[FOCUS] The exam tests that tuning must be documented and validated, not arbitrary.

Systematic Approach to Reducing False Positives

High false positive rates waste resources and cause analyst fatigue.

False Positive Root Cause Analysis:

- Review sample of 100-200 false positive alerts
- Categorize by root cause
- Common categories: customer type, transaction type, time of day, counterparty
- Identify patterns (e.g., payroll deposits always flagged)

Tuning Solutions by Root Cause:

Root Cause	Tuning Solution
Payroll deposits flagged as structuring	Add exclusion logic for ACH credits with payroll description
Internal transfers between own accounts	Exclude same-owner accounts from velocity calculations
Business operating expenses flagged	Raise thresholds for business customers, add expense category exclusions
ATM withdrawals flagged as cash structuring	Separate ATM from teller cash, apply different thresholds
Low-risk jurisdiction wires flagged	Apply tiered thresholds by jurisdiction risk

Expected Outcome:

- False positive rate reduction of 30-50 percent typical
- Maintain or improve capture rate (ATL)
- Document all exclusion logic for auditors

Detecting What You're Missing

Low capture rate means criminals are operating undetected.

Signs of Low Capture Rate:

- ATL testing shows capture rate below 90 percent
- New SARs filed for typologies existing scenarios should detect
- Law enforcement inquiries about activity not alerted
- Peer institutions filing more SARs for similar typologies

Tuning Solutions for Low Capture Rate:

- Lower thresholds - but test impact on false positives first
- Broaden scenario logic - add more indicators
- Add new scenarios for emerging typologies
- Improve data quality - missing transactions or fields
- Update customer segmentation - ensure high-risk have lower thresholds

Example: Structuring Scenario Tuning

- Original: Alert on 8+ cash deposits | \$10,000 in 30 days
- Capture rate: 82 percent (18 percent missed)
- After analysis: Criminals adapted to 5-6 deposits
- Tuned: Alert on 5+ cash deposits | \$10,000 in 30 days
- New capture rate: 96 percent (4 percent missed)
- False positive impact: Acceptable increase of 15 percent

[FOCUS] Sacrificing some false positive increase is acceptable to improve capture rate.

What Regulators Expect to See for Each Scenario

Every monitoring scenario must have complete, up-to-date documentation.

Required Documentation Elements:

- Scenario Name and ID: Unique identifier for tracking
- Typology Detected: Which money laundering method this targets
- Risk Assessment Linkage: Reference to risk assessment entry
- Customer Segmentation: Which customer types this applies to
- Logic Statement: Exact rule in pseudo-code or SQL
- Threshold Values: All monetary, velocity, and count thresholds
- Time Windows: Rolling periods for aggregation
- Exclusions: Any transactions or customers excluded
- Expected Alert Volume: Monthly estimate by segment
- Validation History: ATL and BTL test results with dates
- Tuning History: All changes with dates and rationales
- Owner: Responsible analyst or team

[ALERT] Missing or outdated scenario documentation is a common audit finding.

Not All Alerts Are Equal

Investigators must focus on highest-risk alerts first. Prioritization is critical.

Prioritization Factors:

- Customer Risk Tier: PEP $\downarrow$ High $\downarrow$ Medium $\downarrow$ Low
- Transaction Amount: Larger amounts prioritized
- Jurisdiction Risk: High-risk countries prioritized
- Scenario Type: Certain typologies flagged as higher risk
- Velocity: Multiple alerts on same customer
- Recency: Newer alerts (FIFO or LIFO based on policy)

Priority Scoring Example:

- Score = (Customer Risk Weight $\times$ 5) + (Amount Score $\times$ 3) + (Jurisdiction Score $\times$ 2)
- High Priority (score $\geq$ 80): Review within 24 hours
- Medium Priority (score 50-80): Review within 3 days
- Low Priority (score $\leq$ 50): Review within 7 days

Aging Requirements:

- Regulators expect timely alert review
- Typical SLA: 90 percent of alerts reviewed within 30 days
- High-priority alerts: 100 percent within 48-72 hours
- Aging reports must be reviewed by management weekly

[ALERT] Old, unreviewed alerts are a regulatory deficiency.

Matching Resources to Alert Volume

Alert volume must be aligned with investigator capacity.

Capacity Calculation:

- Average time per alert review: 15-30 minutes
- Average alerts per investigator per day: 16-32
- Effective working days per year: 220 (after training, meetings, leave)
- Annual capacity per investigator: 3,500-7,000 alerts

Capacity Planning Formula:

- $\text{Required Investigators} = (\text{Monthly Alert Volume} \times 12) / \text{Annual Capacity per Investigator}$
- Example: $8,000 \text{ alerts/month} \times 12 = 96,000 \text{ alerts/year}$
- $96,000 / 5,000 \text{ (mid-range capacity)} = 19.2 \text{ investigators}$
- Add 20

Capacity Warning Signs:

- Aging alerts exceed SLAs consistently
- Investigators working overtime regularly
- High turnover in monitoring team
- Quality review finds errors from rushing
- Management rejects requests for additional headcount

[ALERT] Understaffing leading to unreviewed alerts is a regulatory violation.

Every Alert Must Have a Final Determination

No alert can be left unresolved. Each requires documented disposition.

Valid Dispositions:

- False Positive: No suspicious activity found. Document why.
- True Positive - No SAR: Suspicious but below filing threshold or mitigated. Document rationale.
- True Positive - SAR Filed: Suspicious activity meeting filing criteria. SAR submitted.
- Referred to Another Unit: e.g., Fraud, Legal, or Relationship Manager. Document referral.
- Pending Additional Information: Awaiting response from customer or internal source. Must have follow-up date.

Investigation Documentation Requirements:

- Customer information reviewed (KYC, CDD, EDD)
- Transaction details analyzed (amounts, dates, counterparties)
- External research performed (OSINT, databases)
- Analysis and rationale for disposition
- Supporting evidence attached (screenshots, reports)
- Supervisor approval for certain dispositions
- Audit trail of all actions and views

[ALERT] Inadequate investigation documentation is a common quality assurance finding.

Systematic False Positive Reduction

Tracking false positive categories enables targeted tuning.

Common False Positive Categories:

Category	Example	Tuning Solution
Payroll	Regular salary deposits flagged as structuring	Add payroll exclusion logic
Internal Transfers	Moving money between own accounts	Exclude same-owner accounts
Business Expenses	Rent, utilities, supplies flagged	Raise business thresholds
Low-Risk Jurisdiction	Wire to Canada flagged as high-risk	Tier thresholds by risk
Data Error	Corrupted field causes false match	Fix data quality issue
Threshold Too Low	<i>500wiretriggersalert</i>	Raise threshold
Logic Too Broad	Any wire over 1,000 <i>flagged</i>	Narrow logic conditions
Segmentation Missing	Retail and corporate same rules	Implement segmentation

False Positive Tracking Metrics:

- False positive rate by scenario (identify worst performers)
- False positive rate by customer segment (identify over-monitored segments)
- False positive rate by investigator (identify training needs)
- Root cause distribution (guide tuning priorities)

[FOCUS] The exam tests that false positive analysis should drive scenario tuning.

Ensuring Investigation Quality

Regular QA reviews validate that alerts are properly investigated and dispositions are correct.

QA Sample Methodology:

- Random sample of all closed alerts (typically 5-10 percent)
- Oversample high-risk alerts (100 percent of PEP alerts)
- Oversample SAR decisions (100 percent of SAR filings)
- Include false positives, true positives, and referrals

QA Review Criteria:

- Completeness: All required fields populated?
- Accuracy: Is disposition supported by evidence?
- Timeliness: Was alert reviewed within SLA?
- Documentation: Is rationale clear and complete?
- Consistency: Similar cases decided similarly?

QA Findings Severity:

- Critical: Missed SAR should have been filed. Immediate remediation.
- Major: Significant documentation gaps or procedural errors.
- Minor: Minor documentation issues, no impact on decision.

[ALERT] QA program must be independent of the investigation team.

Learning from Past Mistakes

Back-testing runs historical transactions through current scenarios to identify missed suspicious activity.

Back-Testing Methodology:

- 1 Select historical period (e.g., previous 12 months)
- 2 Run all transactions through current monitoring scenarios
- 3 Identify transactions that would generate alerts today but did not at the time
- 4 Review these missed transactions for suspicious activity
- 5 File SARs for any suspicious activity identified
- 6 Tune scenarios to prevent future misses

Trigger Events for Back-Testing:

- New scenario deployment (test against historical data)
- Major threshold changes (validate improvement)
- After discovering a previously undetected typology
- Regulatory request or examination finding
- Material change to sanctions lists

Regulatory Expectation:

- Back-testing after significant scenario changes
- Documentation of review and any SAR filings
- No specific frequency mandated, but risk-based

[FOCUS] Back-testing discovered the 18-month gap in the over-filtering trap scenario.

When Regulators Require Historical Reviews

Look-back reviews examine historical transactions after discovering a control failure.

Common Look-Back Triggers:

- Silent data feed failure (transactions never monitored)
- Scenario logic error (wrong threshold or condition)
- Missed sanctions list update (screening using old list)
- Model drift without recalibration
- Regulatory finding requiring historical review

Look-Back Scope Determination:

- Time period of control failure (must be identified)
- Transaction types affected (wires, cash, ACH, etc.)
- Customer segments affected (may be all or subset)
- Regulator may mandate specific scope

Look-Back Execution:

- Obtain all missed transactions (may require IT extraction)
- Run through current monitoring scenarios
- Investigate all alerts generated
- File SARs for any suspicious activity identified
- Document all findings for regulators

[ALERT] Failure to conduct a look-back after discovering a control failure is a separate violation.

Metrics Management Must Review Monthly

Regular KPI reporting enables oversight of monitoring effectiveness.

Volume Metrics:

- Total transactions monitored (by channel, product, segment)
- Total alerts generated (by scenario, priority, segment)
- Alert rate (alerts per 1,000 transactions)
- SARs filed (by typology, segment, scenario)
- SAR filing rate (SARs per 1,000 alerts)

Performance Metrics:

- False positive rate (by scenario, segment)
- Capture rate (from ATL testing)
- Alert aging (percentage reviewed within SLA)
- Investigation time (average hours per alert)
- Quality assurance scores

Resource Metrics:

- Alerts per investigator
- Cost per alert reviewed
- Investigator turnover rate
- Training hours completed
- Overtime hours

Reporting Cadence:

- Daily: Alert volume, aging, priority distribution
- Weekly: Investigator workload, emerging patterns
- Monthly: Complete KPI dashboard to management
- Quarterly: Trend analysis to Board

[FOCUS] Management must receive and act on KPI reports. Ignoring negative trends is a deficiency.

What Regulators Cite in Enforcement Actions

These deficiencies appear repeatedly in consent orders.

Most Common Findings:

- Over-Filtering: Thresholds set too high, causing false negatives
- Data Quality: Incomplete or inaccurate data feeds
- Scenario Gaps: Missing scenarios for relevant typologies
- No ATL/BTL Testing: Cannot demonstrate scenario effectiveness
- Outdated Scenarios: Not updated for emerging typologies
- Inadequate Segmentation: Same rules for all customer types
- Alert Backlog: Unreviewed alerts exceeding SLAs
- Poor Documentation: Missing rationale for dispositions
- No Independent Validation: Models deployed without MRM
- Model Drift: Performance degraded without recalibration

Enforcement Consequences:

- Civil money penalties (millions to billions)
- Consent orders with mandated remediation
- Independent monitor required
- Board and management reporting requirements
- Restrictions on growth or acquisitions

[ALERT] Most enforcement actions include at least three of these findings.

Regulatory Expectations Summary

Every transaction monitoring program must include these elements.

Required Program Elements:

- 1 Written policies and procedures for monitoring
- 2 Risk assessment identifying relevant typologies
- 3 Scenarios mapped to each relevant typology
- 4 Documented thresholds with calibration methodology
- 5 Customer segmentation logic
- 6 ATL and BTL testing (at least annually)
- 7 Model risk management and independent validation
- 8 Alert prioritization and triage process
- 9 Investigation procedures and documentation standards
- 10 Quality assurance program
- 11 Management reporting and oversight
- 12 Regular scenario tuning and updates
- 13 Data quality controls and reconciliation
- 14 Audit trail of all monitoring activities
- 15 Back-testing and look-back procedures

[FOCUS] The exam tests that all these elements are required, not optional.

- Transaction monitoring is the primary detective control for ongoing AML
- Rules-based systems are explainable but miss new typologies
- Customer segmentation prevents one-size-fits-all monitoring
- Thresholds must be data-driven, not arbitrary
- ATL tests effectiveness (capture rate)
- BTL tests efficiency (false positive rate)
- Both ATL and BTL are required - not just one
- Over-filtering (thresholds too high) creates false negatives
- False negatives are worse than false positives
- Model risk management requires independent validation
- Model drift requires regular recalibration
- Scenarios must be tuned continuously based on performance data
- Documentation is as important as detection
- Alert backlogs are a regulatory violation
- Quality assurance validates investigation quality

[CORRECT] Master these concepts for the 6-8 transaction monitoring questions on the exam.